

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 1 頁，共 9 頁

單選題 50 題（佔 100%）

A	1. 下列哪一種攻擊手法，主要目的是在破壞「機密性」？ (1) 社交工程 (2) 搜尋引擎攻擊（Google-Hacking） (3) 拒絕服務（Denial-of-Services） (4) 駭客侵入銀行資料庫竄改存款金額 (A) (1), (2) (B) (3), (4) (C) (2), (3), (4) (D) (1), (2), (4)
A	2. 請問「無論是資源、通訊、資料或是資訊等，只能讓經授權的使用者使用」所代表的意義是下列何者？ (A) 機密性 (B) 完整性 (C) 可用性 (D) 可讀性
B	3. 建立資訊系統資料備份機制，與下列何者關聯性最高？ (A) 可歸責性 (B) 可用性 (C) 完整性 (D) 機密性
B	4. 請問系統安全程序、設計、裝置、或內部控制裡的一個瑕疵或缺點，若被運用，會破壞安全性或違背系統安全政策，此為 NIST SP800-30 對下列敘述何者的定義？ (A) 威脅 (B) 弱點 (C) 風險 (D) 衝擊
D	5. 關於文件管制措施，下列敘述何者正確？ (A) 所有制定的 SOP 皆須書面發行 (B) 制定的各項管理制度、程序，不宜以電子檔案公佈 (C) 所制訂管理辦法及作業程序需要被遵守，因此所有人皆可閱讀所有文件 (D) 文件管制宜訂定標準作業程序，以利組織成員遵循
D	6. 關於資訊安全政策的審查，下列敘述何者不正確？

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 2 頁，共 9 頁

	(A) 資訊安全政策應定期審查 (B) 相關法令有重大變更時，應進行審查 (C) 公司主要營業項目有重大改變時，應進行審查 (D) 資訊安全政策之審查由資訊主管單獨進行即可
B	7. 在資訊安全管理系統 (Information Security Management System, ISMS) 的維運過程中，「文件化資訊」是必要的要求，下列何者不是所有文件化資訊需確保的事項？ (A) 制訂需要有可識別的方式，例如：標示文件的標題和日期 (B) 發行需要由文件管理人員審查之後，即可對外公佈發行 (C) 在需要時得提供給相關人員 (D) 需要受到適切的保護，以避免不當使用和外洩
C	8. 資訊安全政策是資訊安全管理系統中的最高指導原則，有不可缺少的重要性，下列敘述何者正確？ (A) 滿足相關的要求事項的承諾後，無需持續改善 (B) 在四階管理文件中屬於第二階管理程序文件 (C) 建立的資訊安全政策必須符合組織的目的及資安目標 (D) 屬於內部或機密文件，不可對外公告
A	9. 資訊資產群組化的好處是簡化並縮短資訊資產之風險評鑑時間，減少威脅、弱點的重複判斷。下列何者資訊資產比較不適合群組化為同一類型？ (A) 機房內的所有主機 (B) 同部門的工作電腦 (C) 識別門禁卡 (D) 系統開發規格書
A	10. 進行資產分類為下列哪一種安全控管類型？ (A) 預防性控制 (Preventive) (B) 檢測性控制 (Detective) (C) 指令性控制 (Directive) (D) 糾正性控制 (Corrective)
D	11. 資訊資產價值需考量資訊資產的機密性、可用性及完整性，下列何種情況是應該考量提高可用性？ (A) 公司官網遭竄改 (B) 未授權存取人事資料 (C) 電腦安裝免費軟體

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 3 頁，共 9 頁

	(D) ERP 系統當機
B	12. 關於資訊資產，下列敘述何者不正確？ (A) 資訊資產安全等級之影響評估構面通常至少會包含機密性、完整性等 (B) 資訊資產重要性等級一旦區分完成，之後不需要再重新檢視或變更 (C) 資產分類分級作業通常是為了之後進行風險管控作業所需 (D) 資產標示並不僅限於硬體資產
C	13. 關於資產分類分級，下列敘述何者正確？ (A) 資產評估不需考量資產之完整性、可用性、機密性 (B) 資產分類分級不需考慮產業別差異 (C) 資產分類分級可以做為風險評估重要的依據 (D) CCTV 系統歸在人資行管部門管控，可不列入分類與評估建議
A	14. 關於雲端服務資產識別議題，下列敘述何者有待商榷？ (A) 租賃雲端服務系統，未列會計科目資產，所以不列入資訊資產盤點項目 (B) 雲端服務資料屬於企業組織之資產 (C) 雲端服務系統，仍屬於資產識別需考量之範圍 (D) 法規的適用上，在雲端資訊資產處理方式，各國無一致標準，需審慎使用
B	15. 在進行資產盤點和建立資產清冊時，下列何者不是必要做法？ (A) 資產清冊需要識別與資訊及資訊處理設施有關的資產 (B) 資產清冊需要標示資產購置時的成本和費用 (C) 對已識別的資訊資產，需要指派資產的擁有者 (D) 資產清冊應予文件化
A	16. 風險不可能不存在，面對風險有哪四種處置的方法？ (A) 接受、降低、移轉、避免 (B) 規劃、評估、排序、避免 (C) 面對、處理、解決、接受 (D) 評估、分析、處理、降低
B	17. 假設災難一定會發生（不論機率再低），當災難發生時，為了確保組織在災難發生時有可遵循的作業程序，以降低損失，所以必須要制定哪一種文件？ (A) 風險管理計畫 (B) 緊急應變計畫 (C) 適用性聲明

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 4 頁，共 9 頁

	(D) 內部稽核計畫
C	18. 為能達成 ERP 系統不中斷的使用要求，資訊單位決定建立 ERP 備援系統，請問這是風險處理哪一種行為？ (A) 風險規避 (Avoid) (B) 風險轉嫁 (Transfer) (C) 風險降低 (Reduce) (D) 風險接受 (Accept)
D	19. 關於風險降低，下列敘述何者不正確？ (A) 其方式包括稽查及遵守計畫 (B) 其方式包括處理偶發事故的計畫 (C) 其方式包括找出相較於現有的控制方法，新的控制方法所可能帶來的相對利益 (D) 其方法包括契約的簽訂、保險和機關的結構，如合夥經營和共同投資
C	20. 關於風險處理，下列敘述何者正確？ (A) 只要進行風險處理，就可以消弭所有的風險因子 (B) 風險處理，不需要考慮成本或法規要求 (C) 風險處理後，可能產生新的風險項目或是殘餘風險 (D) 風險處理僅能選擇暫時接受風險，別無他法
B	21. 關於網路及系統存取管理，下列敘述何者不正確？ (A) 系統主機應考量保護機制，如設定在一段時間未操作時即會自動登出的機制 (B) 若因人為因素誤植帳號及密碼，無需保存紀錄檔 (C) 連線的來源位址與目的位址應建立路由 (Routing) 控管 (D) 管理者應依照使用者身份，控制系統應用程式的存取
D	22. 關於特權管理，下列敘述何者最為正確？ (A) 登入主機應該使用 Administrator or Root 帳號，以利管理相關權限設定 (B) 資料庫管理員除了備份資料外，還需要讀取資料以利調校資料庫效能 (C) 基於代理人機制，系統管理員除了網路管理帳號外也需本機管理帳號 (D) 應該定期審查特權帳號，若有人員離職也須立即審查相關系統帳號
D	23. 為了防止非授權的存取，企業應根據存取控管政策對使用者 (包括內、

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 5 頁，共 9 頁

	外部使用者) 存取權限進行管理。下列何者較無關於管理存取權限？ (A) 定期變更密碼 (B) 定期審查使用者存取權限 (C) 保留存取紀錄 (D) 資料備份
C	24. 您是資訊業務承辦人員，當您有特殊業務需求進行存取敏感性資料時，需要獲得存取許可，即使您有資料存取權限，還需要提出資料存取的理由。上述說明主要為？ (A) 職務區隔 (Segregation of Duties) (B) 最小權限原則 (Principle of Least Privilege) (C) 必要知道原則 (Need-to-know Principle) (D) 以角色為基礎的存取控制 (Role-based Access Control, RBAC)
D	25. 關於權限管理，下列敘述何項較不適？ (A) 採購人員擁有採購系統新增、編修、存檔的權限，但無刪除權限 (B) 總經理只擁有採購系統所有模組的查詢權限 (C) 總經理將採購系統最高管理者的帳號密碼，存放於保險箱未使用，另外使用其他帳號登入系統 (D) 資訊主管的系統帳號已是採購系統管理者，因此無須監控其系統操作行為
A	26. 常見的密碼驗證攻擊中，以下何種方法「不是」透過反覆嘗試密碼的方式破解密碼？ (A) 雜湊注入 (Pass-the-Hash) (B) 暴力攻擊 (Exhaustive Search Attack) (C) 字典攻擊 (Dictionary Attack) (D) 猜測攻擊 (Guessing Attack)
A	27. 使用者在選定密碼時需注意避免太容易被攻擊者破解，請比較下面四組密碼，指出何組密碼較不容易遭到攻擊者破解？ (A) qwA\$c&1!e (B) password (C) 12345678 (D) abcd0229
C	28. 我們常使用密碼來做為認證身份的主要方式，關於密碼強度，下列敘述何者不正確？ (A) 符合密碼複雜性原則可增強密碼強度 (B) 對於複雜程度相同的密碼而言，長度較長的密碼安全度較短密碼

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 6 頁，共 9 頁

	為高 (C) 密碼複雜性原則不包含數字 (D) 密碼複雜性原則不包含圖片
B	29. 為強化身份認證機制，我們常會使用雙因素認證機制，請問下列何種組合並不屬於雙因素認證的定義？ (A) 密碼（Password） + RFID 感應卡（如悠遊卡） (B) RFID 感應卡 + 自然人憑證 IC 卡 (C) 自然人憑證 IC 卡 + 指紋 (D) 指紋 + 密碼
D	30. 下列何者非單一登入（Single Sign-On, SSO）的優點？ (A) 集中權限控管 (B) 降低不同的帳號密碼組合的困擾 (C) 減少重新輸入密碼的程序 (D) 簡訊認證
B	31. 關於 Kerberos，下列敘述何者不正確？ (A) 針對個人通信安全，可進行身份認證 (B) 是一種非對稱金鑰管理機制來進行金鑰管理的系統 (C) 可採複合 Kerberos 伺服器 and 缺陷認證機制來補救 (D) 具備加密機制，可保護資料完整性
C	32. 關於設計網際網路服務使用者身分驗證機制的考量因素，下列何者不正確？ (A) What you know？使用者所記住的身分內容，如：個人識別名稱及對應的密碼 (B) What you have？使用者所擁有之認證裝置，如：金融卡、智慧卡 (C) Who you are？使用者所扮演的角色：如：學代、班聯會主席？ (D) What you are？使用者擁有之特徵，如：指紋、虹膜
D	33. 請問在系統服務裡，關於身分驗證，下列敘述何者正確？ (A) 只要通過身分驗證，就可以暢行無阻。 (B) 身分驗證後，即是擁有最高權限。 (C) 身分驗證後，所有的使用行為都是適合的，不需要軌跡。 (D) 依照最小權限原則，劃分給予適當的權限控管。
C	34. 中華民國目前使用自然人憑證，做為民眾於網路應用時之合法身份識別依據。關於自然人憑證，下列敘述何者不正確？ (A) 自然人憑證是基於 PKI（Public Key Infrastructure）架構下之應用 (B) 自然人憑證在網路上使用時，其代表申請人之身分識別上具有法律效力 (C) 自然人憑證申請一次永久有效，無需換發

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 7 頁，共 9 頁

	(D) 自然人憑證於網路上的相關應用具有不可否認性
C	35. 關於營運持續管理處理策略之選擇，下列敘述何者不正確？ (A) 轉移風險 (Transfer) (B) 避免風險 (Avoid) (C) 調整風險 (Adjust) (D) 接受風險 (Accept)
D	36. 依據「行政院國家資通安全會報通報及應變作業流程」，判定事故影響等級時，應評估資安事故造成之機密性、完整性以及可用性衝擊，下列何者非 4 級事件？ (A) 國家機密資料遭洩漏 (B) 關鍵資訊基礎設施系統或資料遭嚴重竄改 (C) 關鍵資訊基礎設施運作遭影響或系統停頓，無法於可容忍中斷時間內回復正常運作 (D) 機關業務系統或資料遭嚴重竄改
B	37. 將不同的設備或不同時間的日誌進行比對，強化判斷是否為真正資安事件之動作，稱之為？ (A) 根因分析 (Root Cause Analysis) (B) 關聯分析 (Correlation) (C) 暫時解決方案 (Workaround) (D) 升級 (Escalation)
C	38. 請問下列何者可以確定為資安事故 (Security Incident)？ (A) 防毒軟體成功地更新了病毒碼 (B) 監控系統出現「硬碟使用量超過 80%」的訊息 (C) 執行 google 蒐尋，發現結果出現有公司機密文件 (D) 設備廠商進入機房維修
D	39. 企業委託信賴的第三方團隊，對企業網路目標範圍進行安全性評估，找出存在的弱點或錯誤安全設定問題；並藉此瞭解員工對各種攻擊異常事件的反應。該進行哪種測試？ (A) 原始碼測試 (Source Code Review) (B) 壓力測試 (Stress Testing) (C) 迴歸測試 (Regression Testing) (D) 滲透測試 (Penetration Test)
D	40. 您是資安專家，希望能估計營運可承受之最長中斷時間 (Maximum Tolerable Period of Disruption)，而您最有可能從下列何者取得？ (A) 平衡計分卡 (Balanced Score Card)

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 8 頁，共 9 頁

	(B) 風險估算 (Risk Evaluation) (C) 恢復點目標 (Recovery Point Objective) (D) 營運衝擊分析 (Business Impact Analysis)
D	41. 公司或組織願意提供資源建立 Hot Site 即時備援系統，下列何者是較不可能的原因？ (A) 營業項目有法規的要求 (B) 為了符合所訂定的資訊安全目標 (C) 與客戶訂定的合約條款要求 (D) 客戶在公司提供的服務資源上，建立重要機密的管理系統
D	42. 針對相同資料，請問下列三種備份方式，依其執行備份所需的時間，由大到小排列為下列何者？甲：完整備份 (Full Backup) 乙：增量備份 (Incremental Backup) 丙：差異備份 (Differential Backup)？ (A) 甲>乙=丙 (B) 甲<丙<乙 (C) 甲=乙>丙 (D) 甲>丙>乙
C	43. 關於復原的目標時間 (Recovery Time Objective)，下列敘述何者正確？ (A) 實際系統復原的時間 (B) 系統無法復原的時間 (C) 發生災難後，預計完成系統復原的時間 (D) 發生災難後，預計系統可能中斷的時間
A	44. 下列何者非現代常用的備份媒體？ (A) 磁片 (B) 磁帶 (C) 光碟 (D) 外接硬碟
A	45. 智慧財產權 (Intellectual Property Rights) 是指由人類思想、智慧、創作而產生具有財產價值的產物。下列何者不屬於智慧財產權？ (A) 肖像權 (B) 專利權 (C) 著作權 (D) 營業秘密法
C	46. 商標註冊後，商標註冊人享有商標專用權，圖形為『®』，表示某個商標經過註冊，並受法律之保護。關於商標與專利，下列敘述何者不正確？ (A) 專利需要具有發明、新型及新式樣等 (B) 商標是一個圖樣，或文字，或符號，或顏色，或聲音 (C) 德國愛迪達公司控告美國威名百貨銷售的佩雷斯運動鞋有三條

初級資訊安全工程師能力鑑定樣題

科目 1：資訊安全管理概論

第 9 頁，共 9 頁

	線，是非法使用其『愛迪達』專利權 (D) 專利權是對發明授予的權利，對專利權人之發明予以保護，保護權利在一段期間內有效，一般期限為 20 年
B	47. 下列何者不是展現保護智慧財產權的良好做法？ (A) 建立銷毀軟體或是轉讓給他人的政策 (B) 允許暫時超過軟體授權內的使用人數上限 (C) 將合法授權的軟體光碟複製一份作為備用 (D) 妥善保存軟體光碟的授權書和啓用碼
B	48. 根據我國內部稽核協會所訂定之「內部稽核與職業道德規範」，認為內部稽核人員應遵守四大原則，下列何者未包含在其中？ (A) 誠正 (B) 節省 (C) 客觀 (D) 保密
B	49. 下列稽核的程序活動中，何者較為優先？ (A) 評估內部控制之有效性 (B) 規劃稽核目標及範圍 (C) 營運活動的觀察 (D) 準備稽核報告
A	50. 下列何種權利必須到經濟部智慧財產局申請，才可享有？ (a)專利權(b)商標權(c)著作權 (A) (a)(b) (B) (a)(c) (C) (b)(c) (D) (a)(b)(c)

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 1 頁，共 14 頁

單選題 50 題 (佔 100%)

C	1. ISO 27001 ISMS 最新版本已於 2022 年修正發布了，相較於前一個 2013 年版本，該文件增加了哪些安全管理用詞？ (A) Cybersecurity；Information Security (B) Privacy Protection；Information Security (C) Cybersecurity；Privacy Protection；Information Security (D) Cybersecurity；Information Security；Data Protection
C	2. 下列何項是最有可能把資料被歸類為「機密」等級的情境？ (A) 公司員工皆可訪問的內部通訊錄 (B) 供應商提供查閱的產品目錄 (C) 客戶資料中儲存的信用卡號碼 (D) 公司對外公開發布的新聞稿
D	3. 資訊安全管理系統 (Information Security Management System, ISMS) 的導入步驟中，稽核活動的主要目的為下列何項？ (A) 確保該管理系統的完整性 (B) 評估員工的績效表現 (C) 檢查環境硬體設備的完整程度 (D) 確保該管理系統內部控制的有效性
D	4. 關於保護資料之機密性、完整性與可用性描述，下列何項正確？ (A) 應用系統的可用性對組織而言，皆為同等級重要 (B) 公司內部員工的個人資訊，不在機密性的保護範圍 (C) 對所有資訊資料而言，機密性最為重要 (D) 組織之公開資訊對外公布時，資料的完整性需審查後再開放
A	5. 資訊安全長 (CISO) 是組織中負責資訊安全的最高級別的管理職位，下列資訊安全長主要職責何者較「不」適切？ (A) 資訊系統例行性維護

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 2 頁，共 14 頁

	(B) 評估和管理資訊安全風險 (C) 負責確保已施行適當的安全控制措施 (D) 資訊安全策略制定
C	6. 歐盟執委會 (European Commission, EC) 修正後的 2022/2555 (EU) 指令 (即 Security of Network and Information Systems, NIS 2 Directive)，已於 112 年 1 月 16 日生效，以改善歐盟現有的資訊安全態勢，本次修正內容包括擴大該指令所適用的類別與規模，附圖中哪些產業是本次新納管的產業 (Sectors)？ 1. Drinking water (飲用水) 2. ICT service management (ICT 服務管理) 3. Space (太空) 4. Health (健康) 5. Banking (銀行) 6. Waste water (廢水處理) (A) 1、2、3、5、6 (B) 1、4、5、6 (C) 2、3、6 (D) 1、4、6
D	7. 下列「資通安全管理法」的哪一項子法，有定義資通安全演練作業項目之子法為何？ (A) 資通安全責任等級分級辦法 (B) 資通安全管理法施行細則 (C) 資通安全情資分享辦法 (D) 資通安全事件通報及應變辦法
B	8. 關於個人資料保護法 (以下簡稱：個資法) 之規定，下列何者敘述有誤？ (A) 個資法第三條所規範之當事人權利，不得預先要求拋棄 (B) 個資法第八條規定蒐集個人資料應明確告知當事人

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 3 頁，共 14 頁

	之事項，應以書面為之 (C) 當事人查詢或請求閱覽個人資料或製給複製本者， 可以收取必要之成本費用 (D) 對個人資料之蒐集或處理應有特定目的
D	9. 下列何者行為違反個人資料保護法之規定？ (A) 特定目的消失時，公司即刪除該個資 (B) 首次利用非由當事人提供之個人資料，立即告知當事人取得來源及應行告知之事項 (C) 保險公司要求出險之被保險人提供相關之醫療記錄 (D) 當事人請求閱覽其個人資料，公司於 45 天後告知不予同意
D	10. 資通安全管理法將資通安全事件分為四級，請問下列何項是屬於三級資通安全事件？ (A) 非核心業務資訊遭嚴重洩漏，或未涉及關鍵基礎設施維運之核心業務資訊遭輕微洩漏 (B) 非核心業務資訊遭輕微洩漏 (C) 一般公務機密、敏感資訊或涉及關鍵基礎設施維運之核心業務資訊遭嚴重洩漏，或國家機密遭洩漏 (D) 未涉及關鍵基礎設施維運之核心業務資訊遭嚴重洩漏，或一般公務機密、敏感資訊或涉及關鍵基礎設施維運之核心業務資訊遭輕微洩漏
C	11. 關於中華民國「個人資料保護法」中明定「當事人就其個人資料依本法規定行使之下列權利，不得預先拋棄或以特約限制之」的敘述，下列何項錯誤？ (A) 查詢或請求閱覽 (B) 請求補充或更正 (C) 請求公開或製給複製本 (D) 請求停止蒐集、處理或利用
C	12. 下列何者「非」屬 GDPR (General Data Protection Regulation) 明確列入之特種個資？

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 4 頁，共 14 頁

	(A) 哲學信仰 (B) 生物特徵 (C) 犯罪前科 (D) 政治意見
C	13. 關於機密性與隱私權保護的敘述，下列何者有誤？ (A) 機密性通常結合密碼學的方式來保護資料 (B) 隱私權保護其中一個作法是去識別化儲存 (C) 機密性與隱私權保護的控制機制無法共存 (D) 良好權限控管機制有助於強化機密性或隱私權保護
A	14. 關於資產盤點與風險評估的重要性，下列敘述何者錯誤？ (A) 資產盤點與風險評估可以幫助組織確定其所有的資訊資產，只涵蓋硬體與軟體。就可以讓組織了解其擁有哪些資產以及這些資產的位置 (B) 資產盤點與風險評估可以幫助組織確定其資訊資產的價值，包括其對業務運營的重要性和價值。這可以讓組織確定保護這些資產的重要性和程度 (C) 資產盤點與風險評估可以幫助組織確定其資訊資產的風險，包括潛在的威脅和弱點 (D) 資產盤點與風險評估可以幫助組織對其資訊資產進行管理，包括資產的維護、儲存和刪除等。這可以確保資產被正確管理和保護
D	15. 關於實施資訊資產盤點作業必須考慮的諸多因素中，下列敘述何者錯誤？ (A) 資訊資產的價值 (B) 資訊資產的名稱 (C) 資訊資產的存放位置 (D) 資訊資產的風險
B	16. 資訊資產分類分級的目的為下列何項？ (A) 增加資產價值 (B) 管理資產風險

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 5 頁，共 14 頁

	(C) 提高資產可用性 (D) 降低資產建置成本
C	17. 關於實施「資訊分類」作業主要目的之敘述，下列何者最為適切？ (A) 防止儲存在媒體的資訊被經授權的移除 (B) 防止儲存在媒體的資訊被經授權的揭露 (C) 確保組織重要的資訊受到適切等級的保護 (D) 確保公開的資訊受到適切等級的保護
C	18. 關於紙本類之資訊資產保護原則，下列敘述何者最「不」適切？ (A) 內部使用級之紙本類資訊資產，於保管人員暫時離開座位時，不得置於開放空間處 (B) 內部使用級之紙本類資訊資產，於保管人員長時間離開座位時，應放置於上鎖空間或上鎖櫃並隨時上鎖 (C) 密級之紙本類資訊資產，於保管人員暫時離開座位時，得置於開放空間處 (D) 密級之紙本類資訊資產，於保管人員進出上鎖空間或借用上鎖櫃之鑰匙時應作成紀錄
D	19. 盤點資訊資產時，最可能是使用下列何項分級的基本原則？ (A) 資產的物理大小 (B) 採購成本和效益 (C) 資產外觀的可愛程度 (D) 重要性和敏感性
C	20. 若公司機密等級區分為四個等級：極機密、機密、內部使用、一般。有一份資料僅供公司同仁使用、查閱，亦不須加密。請問這份資料歸類於下列何項機密等級最為合適？ (A) 極機密 (B) 機密 (C) 內部使用 (D) 一般

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 6 頁，共 14 頁

C	21. 如附圖所示，下列何項內容為風險回應的主要方式？ 1. 風險避免 (Risk Avoidance) 2. 風險接受 (Risk Acceptance) 3. 風險曝險 (Risk Exposure) 4. 風險轉移 (Risk Transfer) 5. 風險減緩 (Risk Mitigation) (A) 123 (B) 12345 (C) 1245 (D) 145
C	22. 依據 CNS 27001:2023 標準條款要求有關組織應定義及應用資訊安全風險評鑑過程之敘述，下列何者錯誤？ (A) 建立及維持資訊安全風險準則 (B) 資訊安全風險準則應包含風險接受準則以及執行資訊安全風險評鑑之準則 (C) 識別資訊安全風險包含識別資訊安全管理系統範圍內與喪失資訊之機密性、完整性、可用性以及不可否認性相關聯之風險 (D) 分析資訊安全風險以識別風險實際發生時，應包含可能導致的潛在後果以及風險發生的實際可能性
D	23. 在風險處理的成本考量下，下列何種風險處理策略可能是成本最高的？ (A) 接受所有風險 (B) 將風險進行轉移 (C) 盡力降低風險 (D) 追求零風險
A	24. 颱風、水災及地震等是屬於下列何項風險事件？ (A) 環境災害 (B) 蓄意破壞 (C) 設施功能失效

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 7 頁，共 14 頁

	(D) 資訊事件
A	25. 關於資通安全風險管理內容的描述，下列何者較為正確？ (A) 資通安全風險管理是循環的過程，應該定期重新評鑑風險，並根據風險的變動調整控制措施 (B) 資通安全風險管理應該排除所有風險，確保組織完全沒有風險曝露 (C) 僅需進行一次性的資通安全風險評鑑，資通安全風險一旦識別和處理，便不會發生變化 (D) 資通安全風險管理僅需著重法律和規範要求的符合，不需考慮組織的特定資安需求和環境現況
A	26. 若採行多因素身分驗證，除了原本的帳號密碼之外，下列何項的內容可以當成第二階段認證的方式？（請選擇最佳的組合） (A) 個別員工之 IC 識別證、傳輸至個人手機的隨機驗證碼 (B) 身份證字號、傳輸至個人手機的隨機驗證碼 (C) 身份證字號、出生年月日 (D) 出生年月日、個別員工之 IC 識別證
D	27. 關於存取控制的基本管理敘述，下列何者錯誤？ (A) 「責任分擔」是避免高機密資訊由某人完整的持有 (B) 「最低權限」要求每個人都只能擁有完成任務的最低權限 (C) 「知的必要性」是指對於負責的業務需求性有「知的權利」 (D) 「資訊分類」使用者必須完整掌握其權限以外的對應系統與資料
A	28. 關於身份認證技術的敘述，下列何者正確？ (A) 採用生物資訊認證技術需考量錯誤接受率（FAR）與錯誤拒絕率（FRR） (B) 指紋屬於所持之物（Something you have）

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 8 頁，共 14 頁

	(C) 一次性密碼 (OTP) 屬於所知之事 (Something you know) (D) 申辦時提供雙證件確認屬多因子認證 (MFA)
B	29. 系統管理人員應該對系統使用者的密碼實施一些管制措施，下列何項措施「不」是管理人員會採行的管制措施？ (A) 強制要求使用者定期變更密碼 (B) 允許與先前密碼重複 (C) 限制指定時間內連續嘗試登入的次數 (D) 要求密碼的複雜度
D	30. 如附圖所示，採用生物識別作為身分認證機制時，生物特徵識別系統的辨識精確度會有其誤差值的存在，請問附圖中哪些是「最」常用以評估誤差值的種類？ 1. FAR (False Acceptance Rate) 2. EER (Equal Error Rate) 3. CER (Crossover Error Rate) 4. FRR (False Rejected Rate) (A) 1、2、3 (B) 1、2 (C) 2、4 (D) 1、4
C	31. 關於下列資安作為，包含行政管管理類型、實體類型、技術類型等三項，各有其所相對應的安全控制方式。請問附圖中的項目哪些是屬於「技術」類型？（請選擇最適組合） 1. 策略及規範 2. 稽核 3. 加密演算 4. 網路區段分隔 5. 工作區分隔 6. 人員管控 7. 網路架構

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 9 頁，共 14 頁

	(A) 1、2、3 (B) 4、5、6 (C) 3、4、7 (D) 1、4、6
A	32. FIDO 是確保登入流程中伺服器透過與終端裝置協定的安全機制。請問下列何項敘述有誤？ (A) 由 IETF（網際網路工程任務組織）所訂定的一套網路識別標準 (B) 這套識別標準透過公開金鑰加密（Public Key Cryptography）的架構進行多重因素驗證（MFA）以及生物辨識登入來強力且嚴密地保護雲端帳號的個資 (C) FIDO 是 Fast Identity Online 的縮寫 (D) FIDO 是採用公開金鑰基礎架構的驗證模式，在 FIDO 認證伺服器端（FIDO Authentication Server）只保存相對應的公鑰，而私鑰則僅保存在使用者的裝置端，因此使用者在登入時只需提供個資給終端裝置解鎖私鑰，再透過這個步驟解鎖公鑰進行登入
A	33. 零信任架構（ZTA）的假設前提是：在確認可信之前，沒有任何連線、使用者或資產可以信任。主要目的是解決現今網路環境複雜造成信任邊界不明之資安窘境，期望透過對任何資料存取皆永不信任且必須驗證的原則，達成不論在何時何地存取資料皆保證一致安全性之相關技術。請問下列關於 ZTA 的描述何者較「不」正確？ (A) 聚焦保護網路存取，非保護資料/應用存取 (B) 參考美國國家標準技術研究院（NIST）零信任架構，採取資源門戶之部署方式（Resource Portal-Based Deployment），包含 3 大核心機制：身分鑑別、設備鑑別、信任推斷 (C) 根據美國國家標準技術研究院（NIST）頒布標準文件 NIST SP800-207 將 ZTA 分成核心組件與支援組

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 10 頁，共 14 頁

	件，「資料存取政策」歸類在支援組件中 (D) ZTA 架構中的決策引擎組件是負責接收存取請求、決定允許與否與授予存取憑證
A	34. 下列何項「不」是資料庫的資料加密方式？ (A) 資料遮罩（Data Masking） (B) 透明資料加密（Transparent Data Encryption，TDE） (C) 資料欄位加密 (D) 資料庫檔案加密
D	35. 關於僅知原則（Need to Know）、最小權限原則（Principle of Least Privilege）、僅用原則（Need to Use）的描述，下列何者最「不」適切？ (A) 僅知原則強調只有當成員需要特定資訊來完成其職務時，才應該給予存取該資訊的權限 (B) 最小權限原則要求給予成員執行其工作所需的最少權限 (C) 僅用原則指出應該限制成員對系統資源的存取，以防止資訊洩漏和不當使用 (D) 僅知原則、僅用原則及最小權限原則也可應用在資料加密之理論基礎
A	36. 為確保資料安全，有效降低駭客入侵，最「不」應該進行下列何項措施？ (A) 建立強大的密碼和帳戶管理，實施單一身份驗證 (B) 建立備份和恢復計劃，或是高可用性機制 (C) 使用加密技術 (D) 定期進行安全測試和漏洞掃描
A	37. 關於對稱式加密（Symmetric Encryption）與非對稱式加密（Asymmetric Encryption）的敘述，下列何者錯誤？ (A) 非對稱式加密算法包括 DES、3DES、AES 等，這些算法使用相同的密鑰對資料進行加密和解密 (B) 對稱式加密使用相同的密鑰（也稱為加密鑰）來加

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 11 頁，共 14 頁

	密和解密資料。在對稱式加密中，發送方和接收方必須共享相同的密鑰，並且使用該密鑰對資料進行加密和解密 (C) 非對稱式加密是一種加密技術，使用一對密鑰（公鑰和私鑰）來加密和解密資料 (D) 對稱式加密需要發送方和接收方共享相同的密鑰，因此密鑰的管理和分發比較困難
B	38. 數位簽章驗證程序，是執行附圖中的哪些作業行為？ 1. 簽章產生 2. 內容加密 3. 內容解密 4. 簽章驗證 5. 保密傳輸 (A) 2、4 (B) 1、4 (C) 2、3 (D) 1、5
A	39. 關於密碼技術使用的基本要求，兼顧成本與效率之考量，下列敘述何項最為適切？ (A) 選用密碼技術時，須納入適用法律及法規要求事項 (B) 選用密碼技術時，無須考量資訊機密性 (C) 不論所要求保護資訊分類之等級，密碼演算法的強度皆須為一致 (D) 使用密碼技術主要用以保護使用者端點裝置上資訊，網路傳輸不在考量範圍內
C	40. 關於密碼學（Cryptography）所能達成之主要目的敘述，下列何項最「不」適切？

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 12 頁，共 14 頁

	(A) 機密性 (confidentiality) (B) 完整性 (Integrity) (C) 可用性 (Availability) (D) 不可否認性 (Non-Repudiation)
A	41. 當資訊安全事故發生時，下列敘述何者正確？ (A) 資訊安全事故的發生，最好將細節全部記錄下來，以做日後分析使用 (B) 因為是資訊安全事故，僅對內部告知，細節要求不需告知與資訊處理相關的供應商 (C) 資訊安全事故發生如果無法找到根本原因，可以先予以結案 (D) 因為成本資源的限制，增加此資訊安全事故不再重複發生的控制措施，可於日後再實施
C	42. 關於系統稽核日誌的保護機制敘述，下列何者正確？ (A) 稽核日誌紀錄留存的時間，應以設備硬體空間能儲存多久的時間而制定 (B) 系統管理與使用者，需要參考稽核日誌的結果，所以存取權限設定可予以開放 (C) 因應系統稽核日誌也是資訊安全事故的有效證據，所以控管存取權限是最重要的議題 (D) 當保留稽核日誌紀錄受到防毒軟體的限制時，可考量不予以留存
A	43. 關於資安事故通報處理過程之敘述，下列何者有誤？ (A) 事故通報僅能依正式之書面表單向權責主管進行通報 (B) 事故處理單位應迅速處理以減輕公司損失 (C) 事故處理完成後，應將處理過程及結果進行報告 (D) 事故處理完成後，應分析事故發生原因，進行矯正措施

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 13 頁，共 14 頁

C	44. 下列何項「不」是執行資安事件通報時必須提供的資訊？ (A) 受影響的系統及範圍 (B) 事件發生的時間 (C) 嫌疑人的身份 (D) 預估可能的處理時間
D	45. 資安事故的通報程序「不」包括下列何項？ (A) 向連絡窗口通報 (B) 記錄相關細節 (C) 向警察機關報案 (D) 產生事故結案報告
D	46. 關於資訊備份的敘述，下列何者錯誤？ (A) 資訊允許可遺失的時間，就是備份必須實施的頻率依據 (B) 備份媒體因為有機密性的考量，所以適時的加密是要增加的機制 (C) 確認備份媒體的可用性，是定期需要實施的機制 (D) 備份媒體置放於異地後，無須定期盤點
D	47. 關於實作營運持續的敘述，下列何者錯誤？ (A) 營運持續實作的所有過程，皆須以文件化程序留存使用 (B) 啟動營運持續實作過程時，操作同仁須具備一定的經驗及能力 (C) 營運持續實作時可允許中斷時間的依據，需與規劃階段的時間相符合 (D) 營運持續的實作時間與資訊部門可提供資源有所相關，實作時間無須符合管理階層同意的持續性目標
A	48. 試問有關復原時間目標（Recovery Time Objective，RTO）與復原點目標（Recovery Point Objective，RPO）之敘述，下列何者錯誤？ (A) 復原點目標是指在組織發生中斷事件後，該組織就

113 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 6 月 1 日

第 14 頁，共 14 頁

	業務面衡量其所保存資料與發生中斷前 24 小時之資料，差距有多少 (B) 復原點目標主要觀察與評判該機關執行資料備份與備份資料異地存放之頻率，以做為決定是否實施資料備份與備份頻率 (C) 復原時間目標是指機關於發生中斷事件後，該機關對於回復其所提供產品或服務之時間性目標 (D) 主要是做為機關衡量針對該關鍵活動所具備之營運持續能力
A	49. 下列何種系統備援方案提供了最快的恢復時間？ (A) 熱備援 (B) 冷備援 (C) 暖備援 (D) 離線備份
B	50. 異地備援為將企業內所需之資料/系統，分開兩地同步存放。請問關於異地備援的說明下列何項最「不」適切？ (A) 當一地發生事故時，另一地能持續接手運轉提供服務 (B) 有了異地備援便無資料丟失之風險 (C) 可適用於需要業務不中斷的企業組職 (D) 異地備援的建置可能導致投入成本增加

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 1 頁，共 16 頁

單選題 50 題 (佔 100%)

A	1. 關於資訊安全管理系統的描述，下列何項正確？ (A) 資訊安全管理系統最主要在提供組織用以建立、實作、維持及持續改善與資訊安全有關的事項 (B) 影響資訊安全管理系統的風險因素，皆不會隨時間而改變 (C) 組織所採用的資訊安全管理系統實作的措施，皆不會隨時間而改變 (D) 組織資訊安全管理系統的建立及實作，不會因為規模大小及性質所影響
B	2. 組織向第三方驗證公司申請 ISO 27001 資訊安全管理系統證書，下列步驟何項正確？ (A) 初次驗證通過後，需要不定期重新驗證以取得證書 (B) 初次申請驗證流程，分為文件審查與實地審查兩個階段 (C) 重新審查只需要進行文件審查即可 (D) 組織取得通過驗證證書後，三年進行一次重新審查即可延續證書有效期限
D	3. 下列何者「不」是 ISO/IEC 27001:2022 轉版變化的重點？ (A) 管理系統與 ISO 結構的一致性 (B) 簡化標題 (C) 新增控制項目 (D) 驗證範圍調整
B	4. 資訊安全三個主要基本要素「不」包含下列何項？ (A) 機密性 (B) 安全性 (C) 完整性 (D) 可用性

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 2 頁，共 16 頁

D	5. 組織應於各相關部門及層級建立資訊安全目標，請問下列何項「不」是規劃資訊安全目標主要考慮事項？ (A) 與資訊安全政策一致 (B) 以文件化資訊提供 (C) 應符合適切性 (D) 容易達成
D	6. 下列何者目前並非數位發展部資通安全署認可之資通安全專業證照？ (A) ISO 27001 LA (B) CISSP (C) iPAS 中級資訊安全工程師 (D) ISO 29100 Lead Privacy Implementer
C	7. 下列何項是支付卡產業資料安全標準？ (A) HIPAA (B) SOC II (C) PCI DSS (D) IEC 62443
D	8. 依據《上市上櫃公司資通安全管控指引》第 12 條規定，「定期辦理資安風險評估，就核心業務及核心資通系統鑑別其可能遭遇之資安風險，分析其喪失機密性、完整性及可用性之衝擊」。請問，該規定所稱定期辦理風險評估，所代表用意為下列何項最為適切？ (A) 可以解決先前評估作業所遺漏之項目 (B) 可以使用不同的評估技術及方法 (C) 有助於提高員工的風險意識 (D) 組織的業務發展帶來的威脅不斷改變

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 3 頁，共 16 頁

C	9. 根據資通安全管理法之規定，主管機關應於其自身完成資通安全事件之通報後，依規定時間完成該資通安全事件等級之審核，下列敘述何項正確？ (A) 通報為第三級或第四級資通安全事件者，於接獲後四小時內 (B) 通報為第三級或第四級資通安全事件者，於接獲後六小時內 (C) 通報為第一級或第二級資通安全事件者，於接獲後八小時內 (D) 通報為第一級或第二級資通安全事件者，於接獲後二小時內
B	10. 上市櫃公司發生資安事件時，依照證交所規範，下列何者需要發布為重大訊息的可能性最小？ (A) 公司官網遭分散式阻斷服務攻擊（DDoS），無法正常提供服務，但公司核心業務不受影響 (B) 內部員工訂便當系統當機，導致員工無法訂便當 (C) 內部文件外洩，但不涉及機密或顧客資料，僅有員工個人資料 (D) 共用檔案系統遭勒索軟體攻擊並加密，但有完整備份，所有資料可迅速恢復
D	11. 關於中華民國「資通安全管理法」之條文內容，下列何項正確？ (A) 為保障著作人著作權益，調和社會公共利益，促進國家文化發展 (B) 為保障營業秘密，維護產業倫理與競爭秩序，調和社會公共利益 (C) 為規範個人資料之蒐集、處理及利用，以避免人格權受侵害，並促進個人資料之合理利用 (D) 為積極推動國家資通安全政策，加速建構國家資通安全環境，以保障國家安全，維護社會公共利益

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 4 頁，共 16 頁

A	12. 下列何種標準是針對雲端服務個人隱私資料的保護？ (A) ISO/IEC 27018 (B) ISO/IEC 27701 (C) ISO/IEC 27001 (D) ISO/IEC 27017
D	13. 請問我國個人資料保護法列為特種個資，但歐盟 GDPR 卻未明確列入特種個資的個人資料是下列何項？ (A) 基因 (B) 健康檢查 (C) 生物特徵 (D) 犯罪前科
D	14. 僅就資訊資產管理作業必須考慮的諸多因素中，下列敘述何者錯誤？ (A) 資訊資產分類 (B) 資產盤點 (C) 資訊資產分級 (D) 安全控制措施
D	15. 下列何者「不」屬於資訊資產清冊可用來支援的項目？ (A) 風險管理 (B) 稽核活動 (C) 事故回應 (D) 財產報廢
D	16. 在建立資訊資產分級政策時，若某資產分類的依據是依其「對企業的營運影響」，下列何者較「不」屬於影響考量？ (A) 資產損失對公司聲譽的影響 (B) 該資產對企業盈利能力的潛在影響 (C) 資訊資產外洩對合作夥伴的潛在影響 (D) 資產所需的技術維護成本

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 5 頁，共 16 頁

C	17. 針對資訊資產的盤點，下列何項資訊資產「不」須列入盤點？ (A) 虛擬資產：如虛擬機器、雲端伺服器等 (B) 久未使用但仍在線上的資料庫 (C) 公司徵才公告 (D) 員工用於工作的平板電腦
C	18. 進行資訊資產分類時，「加密系統作業管理程序」通常會歸在下列四項中的何項類別？ (A) 硬體 (B) 環境 (C) 文件 (D) 軟體
A	19. 在定期進行資訊資產盤點的過程中，發現有些資產未被列入資產清單。這可能對資產管理有何直接影響？ (A) 資產的風險評估無法準確進行 (B) 資產的可用性可能會受到影響 (C) 資產的所有者無法進行適當的存取控制 (D) 資產將喪失機密性
D	20. 某公司在進行資訊資產分級時，發現部分資產被多個業務部門使用，不同部門對該資產的重要性評估存在差異。為了確保這類跨部門資產能夠被有效管理，應採用下列何項措施最為適當？ (A) 每個部門獨立分級，根據各部門的需求各自進行保護 (B) 跨部門共享的所有資產，一律採用最高安全等級進行保護 (C) 透過跨部門協調達成共識，將資產設定為中等安全級別 (D) 從有評估的部門中，選擇最高安全等級進行管理

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 6 頁，共 16 頁

B	21. 依據 ISO 27001:2022 標準條款要求有關組織應定義及應用資訊安全風險處理過程之敘述，下列何者錯誤？ (A) 考量風險評鑑結果，選擇適切之資訊安全風險處理選項 (B) 對所選定資訊安全風險處理選項，其控制措施皆選擇不實作 (C) 產生適用性聲明 (D) 制定資訊安全風險處理計畫
A	22. 在風險評鑑過程，辨識出的低風險項目，多數常以下列何種方式進行風險回應？ (A) 風險保留 (Risk Retention) (B) 風險避免 (Risk Avoidance) (C) 風險降低 (Risk Reduction) (D) 風險轉移 (Risk Transfer)
C	23. 風險是指不確定性對目標的影響，或是損失的不確定性。下列何項「非」不確定性所指的三種情況之一？ (A) 不確定事件是否發生 (B) 不確定何時發生 (C) 不確定發生的地點 (D) 不確定造成的嚴重性

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 7 頁，共 16 頁

C	24. 關於資通安全 (Cyber Security) 的風險擁有者 (Risk Owner) 的角色描述，下列何者較「不」合適？ (A) 風險擁有者負責評估責任範圍內的資訊安全風險，並核定資通安全風險處理計畫 (B) 風險擁有者應確保資風險處理計畫被妥善執行，以降低組織面臨的資通安全風險 (C) 風險擁有者一定要是資通安全領域的專業人士，才有能力評估和處理資訊安全風險 (D) 風險擁有者有責任與其他部門合作，共同識別、評估和管理資訊安全風險
C	25. 如附圖所示。為辦理資通系統安全風險評鑑事宜，組織應訂定該評鑑作業有關作業程序，依照國家資通安全研究院發行之《資通系統風險評鑑參考指引》所介紹之風險評鑑技術及方法，可使用下列何項工具與技術組合？ 1. 根本原因分析法 (Root Cause Analysis, RCA) 2. 後果/機率矩陣法 (Probability and Impact Matrix) 3. 強弱危機分析法 (SWOT) 4. 德爾菲法 (Delphi) 5. 蝴蝶效應分析法 (Butterfly effect) 6. 查檢表 (Checklist) 7. 墨菲定律 (Murphy's Law) 8. 企業營運衝擊分析法 (Business Impact Analysis, BIA) (A) 2、3、4、5、6 (B) 1、3、4、5、7 (C) 1、2、4、6、8 (D) 1、2、6、7、8

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 8 頁，共 16 頁

D	26. 關於存取控制技術的描述，下列何者錯誤？ (A) 任意型存取控制（Discretionary Access Control, DAC）是主體存取客體之權限由擁有者設定 (B) 強制型存取控制（Mandatory Access Control, MAC）是依照主體與客體之分類標籤（Classification Label）給予權限，即使是管理者也無法給予特別權限 (C) 角色為基礎的存取控制（Role-Based Access Control, RBAC）使用角色（Role）來管理權限，對於使用者位於同一個單位或執行相關的工作十分方便有效 (D) 基於屬性的存取控制（Attribute Based Access Control, ABAC）僅能透過單一屬性設定存取控制來達到安全的管控
A	27. 採用生物識別作為身分認證機制時，生物特徵識別系統的辨識精確度會有其誤差值的存在，如果組織需要加強進出人員安全管控時，下列何項是生物特徵識別系統要分別增加及減少誤差值的種類？ (A) 增加 FRR（False Rejected Rate）、減少 FAR（False Acceptance Rate） (B) 增加 FRR（False Rejected Rate）、減少 CER（Crossover Error Rate） (C) 增加 FAR（False Acceptance Rate）、減少 FRR（False Rejected Rate） (D) 增加 CER（Crossover Error Rate）、減少 FAR（False Acceptance Rate）

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 9 頁，共 16 頁

D	28. 如附圖所示。在雲端服務的存取權限控管中，下列哪些做法組合最能有效避免過度授予權限？ 1. 根據角色和職責設置最小權限（Least Privilege），確保員工只能存取必要資源 2. 定期檢查所有使用者的權限，並移除不再需要的存取權限 3. 針對高階人員限制權限，只讓他們擁有讀取權限，避免操作錯誤 4. 啟用自動權限審查，並根據使用者的日常行為動態調整權限 5. 為每個管理員帳戶設置多重要素驗證（Multi-factor authentication, MFA），以防止身分被冒用 6. 記錄並審查管理員操作，確保權限使用的合法性 7. 合併所有管理員帳戶以集中管理權限，並定期審查系統操作記錄以避免權限濫用 (A) 1、2、5、7 (B) 1、3、5、6 (C) 1、2、4、6 (D) 1、2、5、6
B	29. 生物特徵辨識應用在存取權限控制時，所扮演的角色是下列哪一項？ (A) 授權（Authorization） (B) 身分驗證（Authentication） (C) 可問責（Accountability） (D) 正確率（Accuracy）

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 10 頁，共 16 頁

B	30. 存取控制是用以控制使用者與系統、系統與系統之間進行資訊交換和溝通，其概念是作業系統為控制一個主體（Subject），能依照其所得到的權限進行客體（Object）之存取。請問附圖中的選項哪些可以作為客體？ 1. 電子檔案 2. 使用者 3. 運作之程式 4. 印表機 5. 資料集 6. 個人電腦（PC） (A) 2、3、4 (B) 1、4、5、6 (C) 2、3、6 (D) 1、2、5、6
B	31. 在一個醫療場域中，有不同的資料進出需求，下列針對存取控制情境的描述何者較「不」適當？ (A) 應該採用白名單機制，限制未授權的連線 (B) 醫療儀器可以直接透過網際網路遠端維護 (C) 以防火牆區隔辦公區與診間 (D) 讓外部網站可以顯示看診進度
A	32. 採用 FIDO2 作為身分認證是目前的趨勢，關於 FIDO2 的敘述下列何者有誤？ (A) 須加入 FIDO 聯盟認證 (B) 可以應用在企業內部作為身分認證 (C) 可以應用在網際網路之金融應用 (D) 是屬於零信任架構的一環

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 11 頁，共 16 頁

B	33. 政府零信任網路架構係參考 NIST 零信任架構，同時結合向上集中之防護需求，採取資源門戶部署（Resource Portal-Based Deployment）方式，下列何項「不」屬於該核心機制？ (A) 身分鑑別 (B) 系統識別 (C) 設備鑑別 (D) 信任推斷
D	34. 關於 RuBAC (Rule-based Access Control)、MAC (Mandatory Access Control)、DAC (Discretionary Access Control)、RoBAC (Role-Based Access Control) 的描述，下列何者最「不」適切？ (A) RuBAC 根據安全規則來決定使用者是否有存取資源的權限 (B) MAC 是一種存取控制機制，其中存取權限由系統中的政策決定，不允許使用者或擁有者更改 (C) DAC 允許資源的擁有者或使用者決定誰可以存取該資源，提供較大的靈活性 (D) RoBAC 將存取控制權限分配給特定使用者，由存取控制規則決定
C	35. 當公司允許員工使用外部生成式 AI 服務（如 ChatGPT）時，下列存取控制措施，何者最能有效保護公司機密資料不被洩露？ (A) 限制只能在公司內部網路中使用生成式 AI 服務，並通過 VPN 進行監控 (B) 要求員工在使用生成式 AI 服務前，簽署保密協議，承諾不輸入機密資料 (C) 採用資訊分類，並使用適當之過濾技術阻止機密資料被輸入生成式 AI 服務的系統中 (D) 設置使用權限，僅允許經批准的員工使用生成式 AI 服務，並定期審核使用情況

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 12 頁，共 16 頁

B	36. 下列何者並非 RSA 金鑰機制的相關特性？ (A) 使用非對稱加密演算法 (B) 使用單一金鑰加解密 (C) 私密金鑰 (private key) 不可交給他人 (D) 公開金鑰 (public key) 可公開讓有需要之人取得
A	37. 憑證管理中心 (CA) 所管理的憑證中，有部分憑證已有安全顧慮時，應運用下列何種處置方式最為合適？ (A) 註銷憑證 (B) 憑證審核 (C) 發佈憑證 (D) 交互認證
D	38. 如附圖所示，在檢查一個利用第三方服務的電子資料交換系統 (EDI) 應用情況時，資訊安全人員應該確認和證實哪些項目？ 1. 確認加密金鑰符合使用者要求 2. 證實服務供應商只使用了 PSDN (Public Switched Data Network) 3. 確認是否已經對服務供應商的營運情況進行了獨立檢查 4. 證實服務供應商的合約包了必要的條款，例如稽核查核的權力 (A) 1、3 (B) 1、4 (C) 2、3 (D) 3、4
A	39. 「生日攻擊法」(Birthday Attack) 主要針對下列何種加密演算法進行攻擊？ (A) MD5 (B) Rijndael (C) 3DES (D) RSA

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 13 頁，共 16 頁

C	40. 2024 年 9 月親俄駭客組織 NoName057 聲稱，將對臺灣政府機關、關鍵基礎設施的網站發動一系列的 DDoS 攻擊。請問此項攻擊主要目的是對被攻擊目標下列何項資訊安全要素造成影響？ (A) 機密性 (Confidentiality) (B) 完整性 (Integrity) (C) 可用性 (Availability) (D) 可歸責性 (Accountability)
B	41. 關於資訊安全事件相關稽核日誌的敘述，下列何者正確？ (A) 系統管理者使用而觸發的系統稽核日誌，皆先留存日誌後再予以審查 (B) 組織可先討論針對系統稽核日誌關心的項目審查，一旦觸發時可優先通知權責主管進行後續處理 (C) 系統管理者因為管理上的需要，可使用到共用的管理帳號 (D) 網路設備留存的稽核日誌，雖然有異常登入的紀錄，但已被阻擋未有資訊安全事故發生，就不須再予以審查
D	42. 依據 SP 800-61 Rev. 2 - Computer Security Incident Handling Guide 文件對於事故回應生命週期 (Incident Response Life Cycle) 之敘述，下列何者錯誤？ (A) 準備 (Preparation) (B) 偵測與分析 (Detection and Analysis) (C) 封鎖、根除與復原 (Containment, Eradication and Recovery) (D) 備份 (Backup)

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 14 頁，共 16 頁

B	43. 關於一般資安事件與重大資安事故的描述，下列何者較「不」適當？ (A) 事件處理時間超過規定時，會升級為事故 (B) 影響資安指標達成之因素或事項者，依其嚴重性評估不會被判定為事件 (C) 一般資安事件與重大資安事故可依照對公司組織的影響程度作為區分 (D) 重要資訊設備失效，通常會歸類為重大資安事故
C	44. 關於資安事件通報，下列何項較「不」是主要目的？ (A) 維護公司形象 (B) 遵守法律法規 (C) 獲得保險理賠 (D) 快速解決問題
B	45. 如附圖所示。當公私部門妥善收集與共享網路威脅情資，將能更快地識別威脅並找出因應之道，進而讓尚未受到威脅衝之組織能因此主動防禦減少事件發生之可能性。我國「國家資通安全研究院」已於《領域 ISAC 實務建置指引》定義「ISAC 情資類型」包含：資安訊息情資（ANA）、資安預警情資（EWA）、網頁攻擊情資（DEF）、入侵攻擊情資（INT）、回饋情資（FBI）等五類。本題提供之情資內容如附圖，請問依情資最適合判別為下列何者？ 司法院資安單位系統監控結果發現，有駭客疑偽冒監察院名義，以公職人員財產申報為由，寄送夾帶惡意附檔之社交工程釣魚郵件予下轄的 A 單位，且已知相關攻擊郵件特徵行為，但尚未確切證據已說明 A 單位已遭受入侵。 (A) 入侵攻擊情資（INT） (B) 資安預警情資（EWA） (C) 網頁攻擊情資（DEF） (D) 回饋情資（FBI）

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 15 頁，共 16 頁

B	46. 關於營運持續性計畫的敘述，下列何者正確？ (A) 營運持續性計畫考量完成時間即可，各關鍵步驟時間有可能會有些微差距 (B) 如果實施營運持續計畫需要供應商的協助，其到場時間亦須納入計畫中 (C) 因為營運持續計畫演練時，操作同仁皆已於異地準備，所以交通時間可以不需納入考量 (D) 啟動營運持續計畫，如果設備有前置準備時間，已於演練前準備完成，該步驟可以不需納入考量
C	47. 關於組織進行營運衝擊分析所需包含之內容敘述，下列何者錯誤？ (A) 辨識關鍵業務相關之活動 (B) 辨識各活動中斷時，會對機關所造成的衝擊 (C) 確認各活動之最小可容忍中斷時間（Maximum Tolerable Period of Disruption, MTPD） (D) 根據各活動復原之優先順序加以分類，藉以鑑別機關之關鍵活動
B	48. 關於災害復原（Disaster Recovery）和營運持續（Business Continuity）差別的敘述，下列何者較「不」適當？ (A) 災害復原確保業務流程所需要的資源能夠得以回復的程序 (B) 災害復原強調業務的韌性以及客戶關係的管理 (C) 營運持續規劃因應事故或營運中斷的策略 (D) 營運持續使業務能在預先規劃的服務等級上持續運行

113 年度第 2 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：113 年 11 月 23 日

第 16 頁，共 16 頁

B	49. 災難發生時，下列何項是最重要的？ (A) 物理資產的保護 (B) 人員生命安全的保護 (C) 維持公司的股票價值 (D) 市場行銷活動的持續進行
A	50. 請問下列何項備援方式，異地備援機制所需時間最長？ (A) 冷備援 (Cold site) (B) 熱備援 (Hot site) (C) 溫備援 (Warm site) (D) 公司機房內建備援

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 1 頁，共 15 頁

單選題 50 題 (佔 100%)

D	1. 關於 ISO 27001 資訊安全管理系統描述，下列何項正確？ (A) 對資訊安全管理之實作，所有組織皆須依照 ISO 27002 實施 (B) ISO 27001 標準只適用於組織對內部人員的要求事項 (C) ISO 27001 標準描述呈現之順序，即為對資訊安全管理系統實作之順序 (D) 組織可導入許多國際標準管理系統，ISO 27001 主要針對在資訊安全
C	2. ISO 27001 資訊安全管理系統中，管理審查會議是屬於 PDCA 中的何項程序？ (A) 規畫 (Plan) (B) 執行 (Do) (C) 檢核 (Check) (D) 行動 (Act)
B	3. 因應客戶的要求，貴公司擬導入個人資料保護的相關標準，因兩個月前您才幫公司完成 ISO 27001:2022 轉版驗證；為達最佳效益，試問您會建議公司導入下列何項認證標準？ (A) ISO 10012 (B) ISO 27701 (C) ISO 27017 (D) ISO 27018
A	4. 在 ISO 27001：2022 的改版重點中，下列何者「不」是本次新增的內容？ (A) 設備汰除或重新使用之保全 (B) 威脅情資 (C) 使用雲端服務之資訊安全 (D) 組態管理

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 2 頁，共 15 頁

C	5. 在 ISMS 管理審查會議中，下列何者「不」是必要考量的事項？ (A) 過往管理審查之決議的處理狀態 (B) 關注方之回饋 (C) 外部利害關係人的參與 (D) 風險評鑑結果及風險處理計畫之狀態
D	6. 根據政府頒佈之資通安全事件通報及應變辦法，受資通安全管理法管制之機關（以下簡稱：受管制機關）進行資通安全事件應變及通報之敘述，下列何者有誤？ (A) 受管制機關知悉資通安全事件後，應於一小時內依主管機關指定之方式及對象，進行資通安全事件之通報 (B) 主管機關應於受管制機關完成資通安全事件之通報後，通報為第一級或第二級資通安全事件者，於接獲後八小時內完成資通安全事件等級之審核 (C) 主管機關應於受管制機關完成資通安全事件之通報後，通報為第三級或第四級資通安全事件者，於接獲後二小時內完成資通安全事件等級之審核 (D) 受管制機關知悉資通安全事件後，第三級或第四級資通安全事件，應於知悉該事件後七十二小時內完成損害控制或復原作業，並依主管機關指定之方式及對象辦理通知事宜

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 3 頁，共 15 頁

A	7. 如附圖所示。王小明在直轄市政府擔任資安專責人員，為將次年度資訊安全相關演練事宜（如社交工程演練、資通安全事件通報及應變演練）規劃結果陳報主管核准，請問，如附圖公文擬稿文字中的 A/B/C，所代表的項目為何，將可達到合規遵法最基本要求？ 主旨：(略) 說明： 一、依據《A》第 8 條第 2 項規定，本單位應辦理如社交工程演練、資通安全事件通報及應變演練等資安作業。 二、擬執行次數： （一）社交工程演練：預計於明年辦理 B 次。 （二）資通安全事件通報及應變演練：預計於明年辦理 C 次。 …（以下略） (A) 資通安全事件通報及應變辦法／2／1 (B) 資通安全責任等級分級辦法／2／1 (C) 公務機關所屬人員資通安全事項獎懲辦法／1／2 (D) 資通安全情資分享辦法／1／2
A	8. 台灣某國際商業銀行為一家 Visa、MasterCard 等信用卡發卡銀行，為了確保持卡人的信用卡資訊及付款資料，能在安全可信的環境中處理、傳輸或儲存，進而建置國際公認且專屬信用卡資訊處理保護的管理制度。請問此制度的最有可能為下列何項？ (A) PCI DSS (B) GDPR (C) HIPPA (D) Sarbanes-Oxley
D	9. 有關資通安全演練作業類型的規定，是明定於《資通安全管理法》的哪一項子法？ (A) 資通安全責任等級分級辦法 (B) 資通安全管理法施行細則 (C) 資通安全情資分享辦法 (D) 資通安全事件通報及應變辦法

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 4 頁，共 15 頁

B	10. 關於 ISO 27001:2022 標準中，要求文件化資訊的項目，下列哪一項錯誤？ (A) 資訊安全政策 (B) 最高管理階層的領導作為 (C) 資訊安全管理系統（ISMS）範圍 (D) 資訊安全目標
D	11. 下列何項與 GDPR（General Data Protection Regulation）規範的要求不符？ (A) GDPR 為歐盟一般資料保護法規 (B) 要求持有歐盟個人可識別資訊的組織，需實施安全控制措施以防止個人資料遺失 (C) 任何使用與歐盟居民相關資訊的組織都須遵循 (D) 僅規定位於歐盟地區的公司組織須遵守
C	12. 請問下列何項屬於個人資料保護法第六條所規範，除符合特定情形，不得蒐集、處理或利用之個人資料？ (A) 姓名 (B) 職業 (C) 健康檢查的報告內容 (D) 國民身分證統一編號
C	13. 請問以下何項「不」是著作權法所述之「著作權之標的」？ (A) 攝影著作 (B) 電腦程式著作 (C) 單純為傳達事實之新聞報導所作成之語文著作 (D) 圖形著作
B	14. 關於資訊資產管理中資產盤點的敘述，下列何項正確？ (A) 資產盤點僅是採購資產時進行之活動 (B) 資產盤點應該定期進行 (C) 資產盤點僅需盤點數位資產 (D) 資產盤點僅需盤點軟體資產

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 5 頁，共 15 頁

C	15. 某組織在進行資訊資產分類及保護的過程中，會明定不同角色人員以確保其功能與職責，一般常見為稱擁有者（Owner）、保管者（Custodian）、使用者（User）、稽核員（Auditor），參考 CNS 27002:2023 對資產擁有者的相關職掌項目定義後，請問下列何項最可能「非」屬擁有者必要負責之工作事項？ (A) 確保已對系統、資訊及其他相關聯資產完成盤點 (B) 確保將資訊及其他相關聯資產適切分類分級並保護之 (C) 確保資產以最低成本進行採購 (D) 確保資訊及其他相關聯資產於刪除或棄置時，以安全方式處理
B	16. 下列何項「不」是 ISO 27001 對於資訊之分類分級的要求？ (A) 依組織之資訊安全需要 (B) 依資安管理系統最高管理者（資安官）之偏好 (C) 考量分類分級方案中對機密性、完整性及可用性之要求事項 (D) 考量相關關注方要求事項
C	17. 如附圖所示。企業為確保資訊資產能獲得適切保護而依照 CNS 27001:2023 建置資安管理制度，並瞭解 CNS 27002:2023 所規定的資訊資產相關控制措施主要有附圖中的 4 項。請問下列的執行順序何者較為適宜？ 1. 資訊之分類分級 2. 編製資訊及其他相關聯資產之清冊 3. 資訊的處置（如傳送、歸還等） 4. 資訊之標示 (A) 3、2、4、1 (B) 4、1、3、2 (C) 2、1、4、3 (D) 3、4、1、2

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 6 頁，共 15 頁

B	18. 行政院發布的《文書處理手冊》所規定「公文紙格式」中，有一個欄位稱為「密等及解密條件或保密期限」。請問，依據其特性並對照 CNS 27002:2023，較屬於下列何項資訊資產管理機制的管控措施？ (A) 5.11 資產之歸還 (B) 5.13 資訊之標示 (C) 5.9 資訊及其他相關聯資產之造冊 (D) 5.10 可接受使用資訊及其他相關聯資產
A	19. 有關 NIST 定義資料生命週期的資料運用狀況，依方式和時間點不同而有不同狀態。請問，當資料在非永久性儲存硬體、應用軟體等情境時，如 RAM、CPU、DLP Agent，可將其歸類於下列何狀態？ (A) Data in use (B) Data on the fly (C) Data in motion (D) Data at rest
C	20. 關於紙本類之資訊資產保護原則，下列敘述何者最「不」正確？ (A) 內部使用級之紙本類資訊資產，於保管人員暫時離開座位時，不得置於開放空間處 (B) 內部使用級之紙本類資訊資產，於保管人員長時間離開座位時，應放置於上鎖空間或上鎖櫃並隨時上鎖 (C) 密級之紙本類資訊資產，於保管人員暫時離開座位時，得置於開放空間處 (D) 密級之紙本類資訊資產，於保管人員進出上鎖空間或借用上鎖櫃之鑰匙時應作成紀錄

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 7 頁，共 15 頁

C	21. 風險評鑑發現，公司內部機密外洩的風險過大；資訊單位導入資料外洩防護（DLP）系統做為因應措施，請問資訊單位的做法是屬於下列何種風險回應？ (A) 風險保留（Risk Retention） (B) 風險避免（Risk Avoidance） (C) 風險降低（Risk Reduction） (D) 風險轉移（Risk Transfer）
A	22. 下列何者「不」是風險位階矩陣中風險發生機率的三個等級之一？ (A) 無 (B) 低 (C) 中 (D) 高
D	23. 關於風險管理循環執行順序的描述，下列何者較為正確？ (A) 風險識別 > 風險處理 > 風險分析 > 風險評估 (B) 風險評估 > 風險識別 > 風險處理 > 風險分析 (C) 風險處理 > 風險識別 > 風險分析 > 風險評估 (D) 風險識別 > 風險分析 > 風險評估 > 風險處理
C	24. 系統在完成測試並確認了變更作業後，就得以開始進行「系統轉換」，以更換至另一個系統或軟體版本，目前實務上常見的「系統轉換」方法有下列四種：並行式（Parallel）轉換、階段式（Phased）轉換、一次性（Abrupt）轉換、引導式（Pilot）轉換。請問，下列何項系統轉換方式的轉換作業風險是最大的？ (A) 並行式（Parallel） (B) 階段式（Phased） (C) 一次性（Abrupt） (D) 引導式（Pilot）

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 8 頁，共 15 頁

D	25. CNS 31010 提供系統化風險評鑑方法選擇及應用的指引文件，摘列適用於各個層級的風險評鑑方法，其中有一項稱之為「企業衝擊分析」(BIA)。請問運用此項方法的最大好處為下列何項？ (A) 無需再執行風險分析作業 (B) 無需定期進行重新評估，不會所受到影響或衝擊不會改變風險值 (C) 僅使用定性評估方式就可以完成 (D) 可以增進企業業務持續運作的意識
D	26. 當密碼作為鑑別資訊時，依最佳實務作法之建議，選用高強度密碼，下列何者較「不」屬於高強度密碼？ (A) 密碼非依辭典字詞或其組合 (B) 使用易於記憶之通行片語，並須包含文數字及特殊字元。 (C) 要求密碼符合一定長度 (D) 密碼可依他人可使用個人之相關資訊，例如姓名、電話號碼、出生日期
D	27. 對於 SSO (Single Sign On) 的描述，下列何者較「不」適切？ (A) 一次登入可以對應多個系統帳號 (B) 每個系統都有自己的帳號 (C) 當系統、API 修改或系統異常，信任關係即失效 (D) 可記憶密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 9 頁，共 15 頁

C	28. 在 ISO 27001 的遠距工作管理規範下，若一個組織決定完全禁止遠距工作，並在其聲明中將該控制措施標註為「不適用」，下列何者描述最能與該聲明相符？ (A) 確保現階段組織內無員工進行遠距工作，並在文件中說明該控制項不適用 (B) 確認組織未來可能的業務需求和風險變化，以便根據需要靈活調整遠距工作政策 (C) 確認並記錄在所有情況下（包括應急或特殊情況）都禁止遠距工作，並提供相應的證據 (D) 定期審查和更新遠距工作政策，即使目前遠距工作被禁止，仍需為未來需求保留調整空間
B	29. 採用多因子身分認證機制，主要目的是避免什麼攻擊方式，以下描述何者較「不」適切？ (A) 避免生物特徵被竊取或挾持 (B) 避免個資拼圖 (C) 避免遭受鍵盤側錄 (D) 避免單一機制被暴力破解
A	30. 下列何項「不」是資料庫的資料加密方式？ (A) 資料遮罩（Data Masking） (B) 透明資料加密（Transparent Data Encryption，TDE） (C) 資料欄位加密 (D) 資料庫檔案加密

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 10 頁，共 15 頁

B	31. 數位憑證 (Digital Certificate) 是在網際網路上識別人員和資源的電子檔案，能夠讓兩個實體之間能夠進行安全、機密的通訊。請問下列何項「不」是數位憑證的正確描述？ (A) 使用在伺服器上的數位憑證又稱為「伺服器憑證」、HTTPS/SSL 憑證，SSL 憑證是在網頁伺服器（主機）與網頁瀏覽器（客戶端）之間建立一個密碼連結的標準規範 (B) 一般網頁用的 SSL 憑證檔案中包含公鑰資訊、擁有者身分資訊、數位憑證發行者、憑證有效到期日，但是不會出現發行憑證日期 (C) 大部分的瀏覽器會在網址列裡顯示一個鎖的圖示或是其他識別方式，如果要了解 SSL 憑證的細節，只要點擊鎖的圖示即可 (D) 憑證用途非常廣泛，像是自然人憑證、工商憑證、健保卡等都是屬於數位憑證的用途，幾乎身分與機構識別都有利用到此技術
D	32. 在存取控制或零信任中，常提到 AAA 原則或 3A 管制、3A 框架，下列何項「不」是其中之一？ (A) 驗證身份 (Authentication) (B) 檢查授權 (Authorization) (C) 記錄行為 (Accounting) (D) 帳號管理 (Account Management)
C	33. 請問下列何種生物特徵 (Biometrics) 類型的效期最短？ (A) 指紋識別 (B) 虹膜識別 (C) 聲紋識別 (D) 掌形識別

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 11 頁，共 15 頁

D	34. 當使用者主張自己的身分後，系統應該確認使用者是否為所宣稱的合法身分擁有者，這個證明使用者身分的過程就被稱為「身分驗證」(Authentication)，常見的身分驗證方法，下列敘述何者最「不」適切？ (A) 所知之事 (Something you Know)：密碼、PIN Code、安全問答等 (B) 所有之物 (Something you Have)：Token、USB 金鑰、智慧晶片卡 (Smart Cards) (C) 所具之形 (Something you Are)：生物特徵 (指紋、虹膜、聲紋等) (D) 所用之物 (Something you Use)：透過使用者所使用的裝置，例如電腦、瀏覽器類型或作業系統來確認身分
B	35. 信任運算基礎 (Trusted Computing Base, TCB) 是指系統內所有對安全性至關重要的硬體、軟體與控制機制，這些組件的正確性與完整性決定了系統的整體安全性。關於 TCB 的設計原則，下列敘述何者最「不」適切？ (A) 完整性保護 (Integrity Protection)：TCB 內的關鍵組件應該受到完整性驗證 (如 TPM、數位簽章)，確保未被竄改 (B) 高安全性 (High Security)：將所有安全相關應用程式都納入 TCB (C) 最小權限原則 (Least Privilege)：TCB 內的組件應只擁有執行必要功能的最低權限，避免濫用 (D) 最小 TCB (Minimization)：TCB 應該儘可能小，以降低攻擊面並提升可信度

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 12 頁，共 15 頁

D	36. 請問數位簽章的主要作用為下列何項？ (A) 加密資料 (B) 解密資料 (C) 生成隨機數 (D) 驗證資料的完整性與來源
C	37. 假設手上有一組金鑰對，其中金鑰 A 能將明文 x 變成密文 y；金鑰 B 能將密文 y 變成明文 x，這二把金鑰非屬同一把金鑰，且當加密演算法所用的運算函數為指數運算 (mod) 時，請問所用的加密演算法較有可能是下列哪一項？ (A) ECC (B) AES (C) RSA (D) DES
D	38. 對達成使用密碼技術的資訊安全目標，下列何項描述有誤？ (A) 機密性：使用資訊加密可以保護敏感資訊 (B) 完整性：使用數位簽章加密機制於檔案，以確保資料完整性傳遞 (C) 不可否認性：對資料使用密碼技術，以提供事故發生時存取相關的證據 (D) 可用性：使用密碼技術以鑑別使用者對資源存取異動時的證據
D	39. 關於使用者管理密碼之方式，下列敘述何者較「不」適當？ (A) 使用強密碼（複雜性密碼） (B) 定期更改密碼 (C) 避免多個帳號使用相同密碼 (D) 使用自動登入儲存密碼，以避免忘記密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 13 頁，共 15 頁

B	40. 關於權限管理，下列敘述何者較「不」適當？ (A) 使用者如有需求，應依組職規定，向權責主管提出權限申請 (B) 權責主管在收到使用者權限申請，應依使用者職務需求，核准其工作所需最大權限 (C) 系統管理人員不得擅自執行未經核可之權限異動 (D) 如有系統遠端維護之需求，應限制必須為核可的遠端連線來源
A	41. 依據「資通安全事件通報及應變辦法」所訂定的資通安全事件之嚴重等級共有四類，如某一特定非公務機關判別某一個非核心資通系統之資訊遭受輕微竄改，則該事件之嚴重等級為下列哪一級？ (A) 第一級 (B) 第二級 (C) 第三級 (D) 第四級
C	42. 在資安事故管理中，下列何項活動應於事故發生後立即進行？ (A) 計畫的定期審查 (B) 員工教育訓練 (C) 影響範圍評估 (D) 事件記錄歸檔
D	43. 下列何項較「不」屬於資安事故數位證據的要求？ (A) 記錄完整且未遭竄改 (B) 與原件相同的電子證據複本 (C) 所涉資訊系統於記錄時應有正確時間戳記 (D) 於存放證據之文件袋加以彌封

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 14 頁，共 15 頁

B	44. 美國、歐盟及我國皆有針對該國家的企業組織、關鍵基礎設施等機構，規範於發現或發生資安事件時應辦理的相關事項，其中有關重大事件應通報主管機關的時效規定，請問，下列何者的時間為「最短」？ (A) 我國《資通安全事件通報及應變辦法》 (B) 我國《證券期貨市場資通安全事件通報應變作業注意事項》 (C) 歐盟《The Digital Operational Resilience Act》 (D) 美國《Cyber Incident Reporting for Critical Infrastructure Act》
C	45. 某公司發現內部員工涉嫌資料竊取。下列何項措施最能確保調查的合法性？ (A) 立即沒收該員工個人的電腦與手機，並進行全面資料掃描 (B) 在未告知員工的情況下，秘密監控其網路活動與通訊紀錄 (C) 遵循法律程序，取得必要的授權，並保護員工的合法權益 (D) 公司內部成立調查小組，並在未經員工同意下，對其工作區域進行隱蔽式監視
B	46. 關於審查資訊安全營運持續流程的敘述，下列何者較為正確？ (A) 當有新的或重大內、外部議題時，與資訊安全相關的營運持續可於每年定期審查時，再一併納入考量 (B) 組織內部需要安排時程測試資訊安全持續計劃，且須確認與資訊安全持續目標是否一致的結果 (C) 需要納入資訊安全營運持續的資訊系統，視資訊部門可用資源為優先考量 (D) 當營運持續計畫演練完成後，若有需要後續程序調整的內容，可於下次安排演練後再予以調整

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 15 頁，共 15 頁

B	47. 備援計劃的主要目的，下列何者描述較為適切？ (A) 提高系統運作性能 (B) 確保業務持續 (C) 減少員工工作負荷 (D) 增加公司營收
A	48. 在規劃緊急災難復原方法時，下列何項較屬優先的重要核心考慮因素？ (A) 業務流程的關鍵性和對影響的容忍度 (B) 存取權限 (C) 資料類型 (D) 資料容量
B	49. 當組織設定重要系統災害復原之 RTO 為 16 小時、RPO 為 3 天時，下列何項的備份週期係屬最小成本且能符合組織要求之規劃？ (A) 12 小時 (B) 2 天 (C) 5 天 (D) 每週備份
C	50. 某公司遭受勒索軟體攻擊，導致主要系統資料被加密，業務運作受到嚴重影響。在這種情況下，下列何項措施對於確保營運持續性最為關鍵？ (A) 立即支付贖金，以恢復系統運作 (B) 找技術專家破解加密，以恢復資料 (C) 使用未受感染的備份資料，恢復系統運作 (D) 關閉所有系統，暫停服務運作